PENSE-BÊTE · DROIT ET STATUT

DORA : Résilience numérique du secteur financier

01-60 DORA - Résilience opérationnelle numérique du secteur financier, notice ACPR et premier bilan 2025 — source : fiche de révision du module (gemma4, 03/11/2026 ; relu par Claude le 04/11/2026)

À RETENIR

1. Le règlement DORA impose 5 piliers pour harmoniser la résilience numérique et prévoit une clause de revoyure au 17 janvier 2028.
2. L'organe de direction est responsable de la mise en œuvre de la stratégie de résilience et doit approuver un niveau de tolérance au risque.
3. Les systèmes soutenant des fonctions critiques ou importantes doivent faire l'objet de tests au moins une fois par an.

Cadre réglementaire DORA

Notion	À retenir
Accélérateur de résilience	**5 piliers** : risque TIC ; incidents (classification, notification) ; tests de résilience ; risques des prestataires TIC ; surveillance des **prestataires critiques**. Revoyure **17 janvier 2028** ; loi **Résilience** (transposition).
Notice de l'ACPR	Vise **Solvabilité II**, **ORPS** (>15 affiliés) et **intermédiaires d'assurance** (hors micro/PME). S'appuie sur les règlements délégués `2024/1774` et `2024/1773`.

Gestion du risque lié aux TIC

Notion	À retenir
A. Gouvernance et stratégie	L'**organe de direction** est responsable de la mise en œuvre selon l'**article cinq**. L'entreprise documente une **stratégie de résilience opérationnelle numérique** et approuve un **niveau de tolérance au risque**.
B. Sécurité et opérations	Sécurité réseau, **chiffrement** et clés ; criticité des actifs ; accès : besoin d'en connaître, **moindre privilège**, séparation des tâches, authentification forte ; correctifs ; systèmes critiques testés **1 fois/an**.
C. Changements, continuité et crise	Code examiné (tests statiques/dynamiques) ; mise en œuvre ≠ validation, repli ; continuité : scénarios, **durées max. d'interruption et de perte de données** ; revues de l'audit interne ; gestion de crise.
D. Le réexamen annuel	Réexamen **au moins une fois par an** et après **tout incident majeur**. Rapport approuvé par l'**organe de direction** remis à l'**ACPR** sur demande en **format électronique interrogeable**.

Prestataires tiers de services TIC

Notion	À retenir
Principe	Complète (sans remplacer) les règles d'externalisation (lignes directrices **EBA 2019**). Stratégie, fonction de suivi, diligence avant contrat, **registre d'informations**.
Contrats	Sous-traitance autorisée, **localisation des serveurs**, **droit d'audit**, protection des données, plan d'urgence, accès de l'autorité, **réversibilité**, **stratégie de sortie**.
Concentration	Évaluer les alternatives ; prestataires **intragroupe** traités avec la même rigueur.

Premier bilan 9 mois après application DORA

Notion	À retenir
État des lieux	**94 %** des SGP concernées. **84 %** ont remis le registre sur `OneGate`, mais seulement **39 %** traités au niveau européen.
Les incidents	Notification : **4 h** après classification majeure, **24 h** après détection. Majeur : **cyberattaque**, ou fonctions critiques + **2 critères secondaires** (sans tenir compte des mesures compensatoires). Tiers dans **plus de la moitié** des cas ; **60 %** déjà clos.
Les constats des contrôles	À éviter : USB non bloqués, utilisateurs administrateurs, postes/messageries non chiffrés, mots de passe non conformes **ANSSI**, pas de MFA messagerie. Bonnes pratiques : inventaire, procédure incidents, surveillance hors heures ouvrées. Supervision renforcée en **2026**.

Détail des incidents majeurs (SGP)

44
déclarations

32
incidents majeurs confirmés

17
indisponibilités de services TIC

10
exfiltrations de données

3
pannes

2
hameçonnages

22
concernant des prestataires

Pièges et confusions

- ⚠ Confondre le règlement DORA avec une directive à transposer alors qu'il est directement applicable.
- ⚠ Classer un incident en tenant compte des mesures compensatoires prises après sa détection.
- ⚠ Croire que la phase de sélection est la plus robuste de la relation avec les prestataires alors qu'il s'agit du contrôle.
- ⚠ Penser que DORA est subordonné à NIS deux alors qu'il s'agit d'une lex specialis.

Sigles et définitions

DORA	Règlement européen fixant des exigences communes de résilience numérique à 20 catégories d'entités financières.
Risque lié aux TIC	Toute circonstance identifiable liée aux réseaux et systèmes d'information pouvant compromettre leur sécurité ou la fourniture de services.
Fonction critique ou importante	Fonction dont la perturbation peut nuire à la performance financière, à la continuité des services ou à l'agrément.
RoI	Registre d'informations recensant les accords contractuels portant sur des services TIC fournis par des prestataires tiers.
TLPT	Tests d'intrusion avancés fondés sur la menace, réservés aux entités les plus importantes.
Lex specialis	Signifie loi spéciale : DORA prime sur NIS deux pour la gestion du risque cyber et la notification des incidents.

Auto-test

1. Quelle est la date d'entrée en application de DORA ?
2. Quel est le délai maximum pour la notification après une classification majeure ?
3. Quel est le délai maximum pour la notification après la détection d'un incident ?
4. Quel pourcentage des SGP concernées est mentionné dans le premier bilan ?
5. À quelle fréquence le réexamen doit-il être effectué ?

Réponses : **1.** 17 janvier 2025 · **2.** 4 heures · **3.** 24 heures · **4.** 94 % · **5.** Au moins une fois par an et après tout incident majeur

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.